

Legal Dashboard

Raport modificari — v2.37.1 si v2.38.0

Probleme rezolvate si imbunatatiri: Issue / Consecinta / Fix

Generat: 15 iunie 2026 - 47 modificari pe 2 versiuni

Versiunea v2.37.1

19 modificari

Issue	Consecinta	Fix
MONITORING		
Un esec partial al unei instante din fan-out-ul name_soap era interpretat ca disparitie a dosarelor acelei instante, in loc sa fie tratat ca lipsa temporara de raspuns.	Alerte false de dosar disparut si rebaseline care apoi putea inghiti schimbari reale ulterioare; userul pierdea incredere in alerte.	Dosarele instantei care nu raspunde sunt purtate neschimbate in baseline, fara alerta si fara rebaseline; failedInstitutii ajunge in diffNameSoap; alertele source_partial active by default (kill switch MONITORING_PARTIAL_ALERTS_ENABLED=0).
Cheile de dedup pentru alertele name_soap nu erau ancorate per-baseline, deci o a doua tranzitie reala (Apel->Recurs dupa Fond->Apel) lovea acelasi ON CONFLICT DO NOTHING.	A doua schimbare de stadiu legitima era inghitita pe viata si nu mai genera nicio alerta.	Cheile de dedup sunt ancorate per-baseline (s<prevSnapshotId>), aliniat cu pattern-ul din dosarSoap, astfel incat fiecare tranzitie reala noua alerteaza din nou.
Pentru un dosar care apare la mai multe instante (fond + apel ca randuri separate), runner-ul dosar_soap nu avea o selectie stabila a randului si nu semnala ca doar o instanta e urmarita.	Un flip de ordine upstream rotea cheile sedintelor producand zgomot, iar userul nu stia ca dosarul mai apare si la alte instante nemonitorizate.	Runner-ul prefera randul al carui stadiu exista deja in baseline (selectie sticky) si emite o singura alerta informativa ca dosarul apare la N instante, din care doar una e monitorizata.
Un raspuns SOAP PortalJust cu status 200 dar fara envelope-ul CautareDosareResult (pagina WAF/mentenanta sau tag redenumit) era tratat ca zero rezultate.	Producea alerte false dosar_disappeared si resetea snapshot-ul, corupand baseline-ul de monitoring pe baza unei erori de sursa.	Un body 200 fara envelope arunca eroare de sursa in loc de 0 rezultate, oglindind guard-ul ICCJ classifyEnvelope, deci nu mai reseteaza snapshot-ul.
RNPM		
Apelurile RNPM nu aveau timeout per-fetch, fiind singurul upstream fara backstop de timp.	Un upstream lent sau blocat putea tine un fetch atarnat nedefinit, blocand operatia.	Timeout per-fetch pe toate apelurile RNPM via RNPM_TIMEOUT_MS (default 60s).
TTL-ul de idempotency pe RNPM /search era doar 120s, prea scurt fata de durata reala a unei cautari.	Un retry de client putea porni o cautare concurenta cu originalul, ceea ce insemna captcha platit dublu si randuri duplicate.	TTL-ul de inflight idempotency crescut de la 120s la 15min, astfel incat un retry sa se ataseze la cautarea in curs in loc sa porneasca una noua.
MIGRATII		
24 de fisiere .down.sql nu stergeau randul corespunzator din _schema_versions, iar runbook-ul de rollback 0034 referea comenzi stale.	Dupa un rollback, sistemul de migratii credea ca migratia inca e aplicata, blocand reaplicarea si lasand schema intr-o stare inconsistenta.	Toate cele 24 de down-uri sterg acum randul din _schema_versions (plus test-garda pe toate down-urile); runbook 0034 in RUNBOOK.md corectat (migrations -> _schema_versions).
Tabela audit_log nu avea index pe coloana ts, iar purge-ul de retentie rula ca un singur full scan.	Interogari pe timp erau lente si purge-ul tinea un write lock pe un scan complet, blocand alte scrieri.	Migratia 0035 adauga index pe audit_log(ts) iar purge-ul de retentie e chunked, eliberand lock-ul intre bucati.
ICCJ		
Fallback-ul de monitoring id-less cauta cu marcasele scj.ro (*/*) prezente in query si nu stripuia markerii mid-string (ex. 1859/107/2009**/a3.1), inclusiv in target_hash.	Cautarea esua sau nu potrivea dosarul corect, producand identitate de monitoring instabila pentru dosarele ICCJ.	Fallback-ul cauta cu numarul normalizat si stripuieste markerii mid-string, inclusiv la calculul target_hash.
Rutele ICCJ nu validau parametrul sectie si nici plauzibilitatea datelor calendaristice primite.	Valori invalide de sectie sau date imposibile (2026-02-31) ajungeau in fluxul de cautare in loc sa fie respinse devreme.	sectie e validata contra id-urilor Department cunoscute iar datele calendaristic imposibile sunt respinse.
Erorile ICCJ aveau igiena slaba: timeout upstream raporta 500, abort de client zgomota in stderr, 503-ul de kill-switch nu avea cod dedicat iar runner-ul nu distingea tipul de esec.	Clientii nu puteau distinge timeout de eroare interna, log-urile erau poluate de aborturi normale si esecurile de sursa vs parse erau indistincte in monitoring_runs.	Timeout upstream mapat la 504, abort de client tratat silentios, 503 cu code ICCJ_DISABLED + Retry-After, iar iccjRunner scrie coduri distincte ICCJ_SOURCE_FAIL / ICCJ_PARSE_FAIL.
Logica fetchCurrentDosar era inglobata si fara teste, iar regex-ul de docket ICCJ accepta puncte consecutive in auxiliare.	Comportamentul nu putea fi verificat in izolare si docket-uri malformate cu puncte consecutive erau acceptate.	Logica extrasa in modul testabil iccjFetchCurrent.ts (4 teste + test de normalizare) si regex-ul de docket respinge punctele consecutive.

Issue	Consecinta	Fix
OPERATIONAL		
Caddyfile stripuia header-ul Cookie inainte de oauth2-proxy, deci proxy-ul nu-si vedea sesiunea.	Login loop pe stack-ul web committed, care era practic auth-dead si nu permitea autentificarea.	Caddyfile nu mai stripuieste header-ul Cookie, deci oauth2-proxy isi regaseste sesiunea.
Kill-switch-urile ICCJ si RNPM nu erau documentate in fisierele de operare.	Operatorii nu stiau ca pot dezactiva sau ajusta ICCJ/RNPM fara modificari de cod, ingreunand interventia in productie.	.env.example, SECURITY.md si README documenteaza acum ICCJ_ROUTES_DISABLED, ICCJ_TIMEOUT_MS, ICCJ_MAX_RESPONSE_BYTES, ICCJ_ENRICH_BUDGET_MS, RNPM_TIMEOUT_MS si kind-ul iccj la MONITORING_DISABLED_KINDS.
BUILD/CI		
Workflow-ul docker-build.yml nu avea permisiuni restranse iar tag-ul default din docker-compose era invechit.	Token-ul de workflow avea privilegii mai largi decat necesar (suprafata de atac CI) si compose ridica o imagine cu tag gresit.	docker-build.yml primeste bloc permissions: contents: read iar tag-ul default din docker-compose actualizat la 2.37.1.
Un test de timeline al raportului din dashboard depindea de ceasul de perete si pica pe Windows CI la pasi de sincronizare NTP.	Flake intermitent in CI care bloca pipeline-ul fara o cauza reala de regresie.	Testul a fost decuplat de wall clock, eliminand flake-ul cauzat de NTP-step pe Windows CI.
SECURITATE		
Fisiere de smoke-test ICCJ cu PII real erau commit-uite in radacina si directorul .worktrees nu era ignorat.	Date personale reale erau expuse in repo iar worktree-urile riscau sa fie commit-uite accidental.	Fisierele de smoke-test cu PII sterse din radacina iar .worktrees/ adaugat in gitignore.
AI		
Inregistrările de audit pentru alerte nu aveau un actor explicit cand actiunea venea din sistem, nu de la un user.	Audit trail-ul nu distingea clar actiunile automate de cele umane pe alerte.	Actiunile automate pe alerte sunt inregistrate in audit cu un actor de sistem dedicat.
UI		
Export-ul XLSX avea branding nealiniat, anumite texte din UI erau imprecise iar o coloana se sorta lexical in loc de numeric.	Inconsecvente cosmetice in export si sortare gresita a valorilor numerice afisate userului.	Branding XLSX aliniat, copy UI corectat si sortare numerica aplicata pe coloana afectata.

Versiunea v2.38.0

28 modificari

Issue	Consecinta	Fix
MODEL AI		
Modelele AI erau inechite (Claude Opus 4.6 si Gemini 3 Flash), atat pe provider-ul nativ cat si pe rutarea OpenRouter.	Calitate si pricing sub generatia curenta; slug-uri care puteau fi redenumite de provider fara fallback.	Refresh la Opus 4.8 (claude-opus-4-8, anthropic/claude-opus-4.8) si Gemini 3.5 Flash (gemini-3.5-flash, google/gemini-3.5-flash), pricing actualizat si pin pe slug-ul Gemini cu test dedicat.
AI		
Stack-ul OpenRouter chinezesc (GLM/Kimi/Qwen) era cablat in backend, pricing, API-ul de settings, verificarile de stack-purity si frontend (toggle Vestic/Chinezesc, config, manual).	Suprafata de rutare AI complexa si neintretinuta, cu o cale de modele nefolosita in practica.	Eliminat complet stack-ul chinezesc; AiUsageRoutingTag ingustat la native openrouter:western; migratia 0036 coerce-uieste openrouter_stack din chinezesc in western (coloana ramane, randuri istorice intacte).
Slug-urile din OPENROUTER_MODEL_OVERRIDES nu erau validate, iar pair-urile fara doua puncte erau procesate naiv.	Un override gresit putea ruta catre un provider/slug invalid sau arunca la parsare, fara semnal clar.	Validare contra unui allowlist de provideri (anthropic/openai/google), split pe primul doua-puncte cu lookup Object.hasOwn, skip defensiv al pair-urilor malformate si log structurat pe override invalid.
validateAiBody nu limita dimensiunea array-urilor sedinte/parti si nu respingea elementele non-obiect.	Payload-uri mari = cost AI impredictibil; un element non-obiect in parti/sedinte producea TypeError in buildPrompt si raspuns 500.	Cap hard la 500 elemente pe sedinte si parti (reject) plus respingerea elementelor non-obiect inainte de construirea prompt-ului.
Apelurile AI nu inregistrau latenta si tipul de eroare, iar valorile nu erau curatate inainte de persistare.	Observabilitate slaba pe performanta/erori AI; risc de valori invalide scrise in DB.	Migratia 0037 adauga latency_ms + error_type in ai_usage, persistate per call prin wrappere safe care sanitizeaza valorile.
callOpenAI presupunea disponibilitatea Responses API; fallback-ul anterior reutiliza bugetul de timeout si verifica doar abort-ul parintelui.	Pe providerii fara Responses API analiza esua; un timeout intern al carui mesaj continea responses putea cadea gresit pe chat.completions in loc sa propage abort-ul.	Fallback pe chat.completions (max_completion_tokens) cu buget de timeout proaspat si re-throw pe composed.aborted inainte de fallback; abort/auth/rate-limit raman propagate.
SECURITATE		
Boot gate-ul LEGAL_DASHBOARD_ACK_NO_AUTH era redundant fata de cerinta auth_mode=web pentru bind remote.	Doua mecanisme suprapuse pentru aceeasi protectie cresc riscul de misconfigurare; etichete JWT incomplete in .env.example.	Gate-ul retras (web auth forteaza la boot JWT secret >=32 + issuer + audience via validateAuthConfig, altfel boot fatal); .env.example marcheaza JWT_ISSUER/JWT_AUDIENCE ca REQUIRED-WEB si documenteaza JWT_TTL_SECONDS.
Cookie-ul de sesiune folosea SameSite=Lax.	Suprafata reziduala de CSRF pe request-uri cross-site cu navigare top-level.	Cookie de sesiune trecut la SameSite=Strict.
Tokenurile JWT nu puteau fi revocate; logout-ul nu invalida tokenul emis.	Un token furat/post-logout ramanea valabil pana la expirarea TTL, fara cale de revocare.	Revocare JWT: claim jti pe tokenuri, tabela jwt_denylist (migratia 0038), verificare contra denylist la validare, revocare la logout (cookie si Bearer) si purjare zilnica a intrarilor expirate.
Logout-ul avea audit sarac si inghitea esecurile de scriere in denylist; replay-ul unui token revocat nu lasa urma.	Incidente nediagnosticabile: un esec de revocare (SQLITE_BUSY/disk) trecea tacut, iar abuzul de token revocat nu era observabil.	Audit logout cu ip/user_agent/request_id + jtiPresent/vokeSucceeded; rand de audit auth.jwt_revoked la replay; esecul revokeJti logat explicit (best-effort 200, token expira la TTL); audit + heartbeat la purjarea denylist.
Purjarea jwt_denylist depindea de scheduler-ul de monitoring.	Cu MONITORING_ENABLED=0 in web mode, jwt_denylist crestea nelimitat.	Interval zilnic standalone purgeExpiredJti (web-gated) ca denylist sa ramana marginit independent de monitoring.
Raportul de diagnostic al watchdog-ului Electron includea environmentVariables si commandLine, iar redactarea nu acoperea sub-rapoartele workers[].	Scurgere de secrete (chei API, env) intr-un raport de crash, inclusiv prin rapoartele worker-ilor.	Redactare recursiva a environmentVariables + commandLine pe raportul principal si pe workers[], cu helper exportat si acoperire node:test.

Issue	Consecinta	Fix
Dependinte cu CVE-uri deschise (hono, react-router, tmp, esbuild) semnalate de Dependabot.	Vulnerabilitati relevante, inclusiv Set-Cookie injection in hono (direct relevant pentru cookie-ul SameSite=Strict), open redirect react-router, path traversal tmp.	Bump in-range lockfile (hono 4.12.25, react-router 6.30.4, tmp 0.2.7, esbuild 0.28.1) inchizand 8 alerte; CVE-urile neaplicabile/neacoperibile documentate ca lasate intentionat.
MONITORING		
name_soap: suprimarea dosar_disappeared la esec partial de instanta era inerta - failedInstituitii contine codul WSDL (TribunalulCLUJ) iar snapshot-ul numele de afisaj (Tribunalul Cluj). Bug live in v2.37.1.	failed.has(...) returna mereu false, deci suprimarea si carry-forward-ul nu se declansau niciodata; alerte false dosar_disappeared pe joburile institution-scoped cand o instanta pica in fan-out.	Ambele parti normalizate prin normalizeInstitutie inainte de comparatie, cu test de regresie pe string-uri divergente.
Titlul alertelor dosar_new/dosar_disappeared pe monitoring de nume era 'Dosar nou gasit pentru nume: <numar>', punand numarul dosarului gasit dupa 'pentru nume' ca si cum ar fi termenul cautat.	Alerta inducea in eroare: nu afisa niciodata numele monitorizat si parea sa caute dupa numarul de dosar.	name_normalized propagat din runner in diffNameSoap; titlu reconstruit ca 'Dosar nou gasit pentru <nume monitorizat>: <numar>', cu fallback '(monitorizare pe nume)' cand numele lipseste.
PORTALJUST		
Cautarile cu 0 rezultate dadeau eroare. PortalJust intoarce un wrapper gol CautareDosareResponse fara niciun CautareDosareResult (verificat live, 299 bytes), iar guard-ul false-empty din v2.37.1 verifica CautareDosareResult. Bug CRITIC live in v2.37.1.	Fiecare cautare cu 0 rezultate arunca 'envelope absent', aparand ca 'Eroare la comunicarea cu serviciul PortalJust' in Cautare Dosare si ca alerte false 'Sursa indisponibila (5 esecuri consecutive)' in monitoring pe nume si pe dosar, desi serviciul era functional.	Guard-ul verifica acum wrapper-ul CautareDosareResponse (prezent si la 0 rezultate, si cu rezultate) plus forma de tag XML; extractFirst intoarce [] cand CautareDosareResult lipseste = 0 rezultate legitime; respingerea paginilor de mentenanta ramane intacta.
ICCJ		
Rutele ICCJ aveau robustete slaba: 504 fara Retry-After, target_json malformat producea eroare opaca, validare incompleta de input.	Clientii nu stiau cand sa reincearca dupa timeout upstream; erorile de parsare/input nu erau clasificate, ingreunand diagnoza.	Retry-After: 60 pe raspunsurile 504; guard pe target_json malformat -> ICCJ_PARSE_FAIL; validare ruta dosareIccj (sectie/data/disabled) cu teste pe 504/sectie/data/disabled si pe branch-ul ICCJ_PARSE_FAIL.
Regexul normalizeIccjNumar era duplicat, iar lista ICCJ_SECTII exista separat in backend si frontend.	Risc de drift silentios intre cele doua copii, cu comportament divergent intre backend si UI.	Teste de drift care impun egalitatea regexului normalizeIccjNumar si sincronizarea ICCJ_SECTII backend<->frontend.
UI		
Cheile cunoscute de detaliu alerta scapau prin fallback-ul de humanizare: latest_sedinta_at afisat ca raw 2026-11-10T00:00:00, sedinteCount si iccj_id cu etichete englezesti si valori brute.	Detaliu de alerta neprofesional si confuz, cu id intern de deep-link (iccj_id) expus utilizatorului.	latest_sedinta_at -> 'Ultima sedinta' formatat dd.mm.yyyy; sedinteCount -> 'Numar sedinte'; iccj_id suprimat din afisaj (ramane extras pentru link), cu test pe formatare si pe un caz real de fallback.
Disclaimer-ul legal de sub analiza AI lipsea, iar dupa adaugare era randat la 11px.	Lipsa unei mentiuni legale sub output-ul AI; textul prea mic pentru a fi citit confortabil.	Disclaimer legal adaugat sub output-ul single si multi-agent, marit de la 11px la 14px (text-sm), pastrand stilul italic/muted.
OPERATIONAL		
streamCap avea un fallback nelimitat .text() pentru raspunsurile cu body null.	Cale potentiala de consum nemarginit de memorie pe raspunsuri fara body limitat.	Eliminat fallback-ul .text() nelimitat pentru body null, cu test pe branch-ul respectiv.
CSP connect-src indica portul mort 3001.	Directiva CSP gresita fata de portul real al backend-ului (3002), risc de blocare conexiuni in anumite configuratii.	Corectat connect-src de la 3001 la 3002.
Map-ul de cooldown pentru email-test nu evacua intrarile expirate.	Crestere nemarginita a unui map in memorie in web mode (memory leak lent).	Purjarea intrarilor expirate din map-ul de cooldown.
audit_log cap-uia campul detail pe numarul de caractere JS, nu pe bytes.	Payload-urile multi-byte (UTF-8) erau sub-numarate, putand depasi limita reala de stocare.	Cap pe detail calculat in bytes UTF-8, nu in caractere JS.

Issue	Consecinta	Fix
purgeOldAiUsage rula un singur DELETE pe tot istoricul.	Write-lock lung pe SQLite cand istoricul ai_usage e mare, blocand alte scrieri.	DELETE chunked (rowid IN cu LIMIT) ca sa evite lock-ul lung de scriere.
LEGAL_DASHBOARD_BACKUP_OFFSITE_CMD ruleaza eval de shell, fara nota de risc.	Operatorii puteau seta comanda fara constientizarea ca e executata ca shell de incredere.	Documentat explicit ca shell eval operator-trusted in catalogul de securitate.
BUILD/CI		
Lipsea configuratia Dependabot, suita electron node:test nu rula in CI, iar intrarea docker pentru /deploy esua la fiecare run.	Updateuri de dependinte nemonitorizate, regresii electron neacoperite in CI, joburi Dependabot rosii pe /deploy (compose cu nume nestandard, fara Dockerfile).	Adaugat .github/dependabot.yml (npm + github-actions saptamanal, grupat) plus ecosistemul docker (Dockerfile root + compose), eliminata intrarea /deploy rupta cu comentariu anti-readd, si rulara electron *.test.cjs in CI.
DOC		
Blocul legacy idempotent din schema.ts si 0001_baseline.up.sql pot sa drifteze, fara semnal in cod.	Schema initiala intretinuta in doua locuri poate diverge tacut intre runner si blocul tranzitoriu.	Comentariu cross-reference KEEP-IN-SYNC pe blocul legacy din schema.ts catre 0001_baseline.up.sql (test real evitat: ar cere refactor initSchema sau a treia copie SQL).